

ISE 331: Fundamentals of Computer Security

Practice Problems for Lectures 09 to 11

Directions: Below is a set of exercises and problems you should do for practice. Answering this set of questions should be just one part of your preparation for quizzes and exams. In addition to solving these problems you should:

- Review the lecture notes.
- Review your homework assignments.
- Form a study group and test each other on the material.

Note: The solution is provided on the last page. It is strongly recommended that you work on the questions first before going to the solution.

Part I. Multiple Choice

1. Access control is necessary for protecting the _____ aspect(s) of a system.
 - A. Confidentiality
 - B. Confidentiality and Integrity
 - C. Availability
 - D. Confidentiality, Integrity, and Availability
2. Which is a primary reason not to use Access Control Matrix in a large-scale system, like cloud data storage?
 - A. It is inefficient due to the high percentage of empty cells.
 - B. It is difficult to enumerate all access rights of a given user.
 - C. It can only represent a limited number of rights.
 - D. It does not support separating the users to different groups.
3. An administrator grants all access rights within a system which cannot be overwritten by users. This is a typical example of:
 - A. Discretionary Access Control
 - B. Mandatory Access Control
 - C. Role-based Access Control
 - D. Rule-based Access Control
4. Which is NOT a goal of browser sandboxing?
 - A. Protect the computer system and the user from web attackers.
 - B. Isolate websites of different origins from each other.
 - C. Achieve platform independence so browsers can run on different computers.
 - D. Separate the rest of the computer system from the browser.
5. A website bank.com includes a JavaScript script from advertisement.com. What is the origin when the script executes?
 - A. The origin is bank.com.
 - B. The origin is advertisement.com.
 - C. The origin is neither bank.com nor advertisement.com.
 - D. The script will not be executed because of the Same Origin Policy (SOP).

6. Which choice correctly describes what can a website do according to the Same Origin Policy (SOP)?
 - A. A website can only send and read information to/from other websites of the same origin.
 - B. A website can send information to all websites, but can only read responses from the same origin.
 - C. A website can read responses from all websites, but can only send information to same origin websites.
 - D. A website can only read information from other websites of the same origin, but cannot send information.
7. You received a cookie from <http://login.safetravel.com> when you log in. Which choice is correct regarding this cookie?
 - A. The cookie can be used to authenticate you the next time you visit this website.
 - B. Your browser will send this cookie when you visit www.airtravel.com.
 - C. If the cookie is lost or stolen, you will not be able to login to this website again.
 - D. The cookie was encrypted by the server before it was sent to you,
8. Which option made CSRF attack possible?
 - A. The attacker can steal your login information if you use http instead of https.
 - B. The server will ignore cookie verification as long as the request is correct.
 - C. The server cannot distinguish between same-site and cross-site requests.
 - D. Your browser will send the same cookie to different websites.
9. An attacker uploaded a modified image as his avatar on a social media website. The modified image contains malicious code, and other users who load this image in their browser will add the attacker as a friend. This is:
 - A. Cross-Site Request Forgery (CSRF)
 - B. Stored Cross-Site Scripting (Stored XSS)
 - C. Reflected Cross-Site Scripting (Reflected XSS)
 - D. SQL Injection
10. Which choice is NOT correct regarding SQL Injection?
 - A. It affects the server instead of the users' browsers.
 - B. Properly sanitizing user inputs can help reduce the likelihood of a SQL injection.
 - C. The attacker only needs to know one user's username to start the attack.
 - D. It can be done without knowing the structure of http requests sent to the server.
11. What is the defining characteristic of a third-party cookie compared to a first-party cookie?
 - A. It is only used for session management and authentication.
 - B. It belongs to the domain of embedded content, such as an iframe or image.
 - C. It is stored permanently on the hard drive, while first-party cookies are temporary.
 - D. It can only be read by the server and not the browser.

Part II. True or False

1. The "no write up, no read down" rule is more suitable for a system where the integrity of the information is valued more.
2. The Access Control List model is more suitable for distributed systems, like door locks for hotel rooms.
3. Capabilities are unforgeable tokens of authority that are bind to the object being accessed.
4. <https://www.safe.com/home/> and <https://login.safe.com/home/> have the same origin according to the Same Origin Policy (SOP).
5. A website games.cherry.com can set cookie for all websites with a domain suffix of cherry.com.
6. Cookies are used to provide an additional authentication method when users login to a website a second time.
7. If you accidentally opened an attacker's website, you will be safe as long as you don't click any links on this website.

8. Reflected XSS can be stopped if the server stops echoing user input.
9. Replacing user input with escape characters (like using /" instead of ") can help prevent SQL injection.
10. For Cross-Site Request Forgery (CSRF) to be successful, the attacker needs to know the user's cookie.
11. A third-party tracker can only track you if you visit their website directly at least once.
12. Browser fingerprinting can identify a user even if they have disabled all cookies.

Part III. Short Answer

1. The Bell-LaPadula model and the Biba model aim to protect different aspects of information in a system. Provide an example of an action that is acceptable in one system but unacceptable in the other, with proper explanation.
2. A user logged into his bank website, and accidentally opened an attacker's website at the same time. Explain what could happen without the Same Origin Policy (SOP).
3. Assume that your cookie for a website was probably stolen a few seconds ago. Your classmate Samy recommended you to immediately sign out from the website. Will that help or not? Explain.
4. List one similarity and one difference between Cross-Site Scripting (XSS) and SQL Injection.
5. After logging in to a social media website, Bob accidentally clicked the link to an attacker's website. While it seems that nothing happened on the attacker's website, he noticed that he has added a number of friends on the social media website. What type of attack has Bob most likely experienced? Come up with one approach to stop this type of attack that can be done on the browser end.
6. Alice and Samy both have accounts on Elgg.com. Elgg.com is a social media website that allows users to make posts. Those posts are stored on Elgg.com servers.
 - 1) Samy makes an Elgg.com post with the contents (.js files contain JavaScript code):
`<script src="http://Elggmail.com/something.js"></script>`
 Assume Elgg.com does not check user inputs. If Alice opens Samy's post, what would be its origin?
 - 2) Which of the following statements is true about Alice opening Samy's post? Explain.
 - a) Alice's browser is able to make a request to Elggmail.com/something.js without being blocked
 - b) If Elgg.com sanitized all HTML input, Alice's browser would not run something.js.
 - 3) Elgg.com has a reset password functionality that can be triggered by accessing <http://Elgg.com/resetPassword>. It makes a request that sets the currently logged-in user's password to the "password" query parameter input. Assume Elgg.com does not check user inputs. What attack can Samy launch using this setup? Describe what they need to post to achieve this.

Part IV. Calculation

1. A cloud data storage company has eight million users, and hosts a total of one billion files. Assume storing the access rights of one user on one file needs two bytes. Answer the following questions with the approximation $10^3 = 2^{10}$:
 - 1) How much storage space is necessary for this company to store all access rights using access control matrix?
 - 2) Assume that on average, one file is shared with 40 users. How much storage space is necessary to store all access rights using access control list?

Part I Solution:
1-5 DABCA 6-10 BACBC
11 B

Part II Solution:
1-5 TFFFT 6-10 FFTTF
11-12 FT

Part III Solution:

1. In the Bell-LaPadula model, someone with a lower security level can “write up”, creating information with a higher security level. However, in the Biba model, there is the rule of “no write up”, prohibiting someone with a lower security level to create information with a higher security level.
2. Without the Same Origin Policy, there will be no constraints for a website to read responses and information from a different website. In that case, the attacker website can read the information on the user’s bank website, and also read responses sent from the bank website to the user, obtaining personal information.
3. Signing off immediately will help prevent any further damage, since signing off terminates the current session and tells the server to stop using the current cookie. If an attacker is currently sending request to the server with the cookie, his request will no longer be accepted.
4. Similarity:
 1. Both are caused by failure to separate data from code.
 2. Both are caused by unsanitized user input.Differences:
 1. XSS happens on the user’s browser (client-side, or frontend), while SQL injection happens on the database server (server-side, or backend).
 2. XSS scripts are written with browser-executable languages, like JavaScript, while SQL injection scripts are written with SQL, as the name suggests.
5. Cross-Site Request Forgery (CSRF) is the most likely. To stop this type of attack from the browser end, the browser can always attach the originating site when sending a request to the server. Also, the browser can assist the server by implementing the SameSite Attribute, which prevents the browser from sending cookies with cross-site requests when it is set to Strict.
6. 1) Elgg.com.
2)
 - a) True, same-origin policy doesn’t stop sending requests to other websites.
 - b) True, Samy’s post would no longer be interpreted as HTML, just plain text.3) CSRF attack. Luring Alice to visit his website that contains a modified link, Samy can trick Alice into making a request and attaching cookies to cause an unintended password reset.

Part IV Solution:

1. 1) $8 \times 10^6 \times 10^9 \times 2 = 1.6 \times 10^{16} \text{ bytes} = 16000 \text{ TB (or 16 PB)}$
2) $10^9 \times 40 \times 2 = 8 \times 10^{10} \text{ bytes} = 80 \text{GB}$